FR-12 – Step 1: Identify input & output variables

Spec used

Source: `eshop-sut/README.md` (FR-12, SEC-02, SEC-03, SEC-06, FR-04, default accounts) and `api_specification.md` (sections 3.3, 3.4, 5.2, 6). Black-box: spec documents only, no source code.

> **FR-12: Access control**
>
> - The Admin module is only for accounts with `role = 'admin'`.
> - **All** Admin APIs (`/api/admin/*`) and all data-changing APIs (`POST/PUT/DELETE /api/products`, `/api/categories`, `/api/coupons`) must require: (1) a valid JWT token, and (2) `role = 'admin'` in the token.
>
> **SEC-02:** security-relevant APIs require a valid JWT. **SEC-03:** Admin APIs must check `role = 'admin'` in the token, not just that a token exists. **SEC-06 / FR-04:** the profile update API must not let the client change `role`.
>
> **API spec:** token sent as `Authorization: Bearer <token>`. Admin endpoints: `GET /api/admin/users`, `DELETE /api/admin/users/:id`, `GET /api/admin/orders`, `PUT /api/admin/orders/:id/status`, `POST /api/admin/import-products`, `POST /api/admin/coupons`, `DELETE /api/admin/coupons/:id`. Data-changing: `POST /api/products`, `PUT/DELETE /api/products/:id`, `POST /api/categories`, `PUT/DELETE /api/categories/:id`. `GET /api/coupons` is labelled "for Admin" (5.2). Public: `GET /api/products`, `GET /api/products/:id`, `GET /api/categories`.
>
> **Accounts:** admin `admin@eshop.com` / `Admin123!` (README; the setup guide says `admin123`), user `test@eshop.com` / `Test1234!`.

Defaults applied (change any you disagree with)

1. Both layers are in scope: the **admin web app** (`:5174`) and the **API**. FR-12 says the admin *module* is admin-only, so the web app must also refuse non-admins.
2. The access rule depends on three things at once: **who** (token and role), **which endpoint**, **which method**. Each is its own variable.
3. **Public read endpoints** are included as a control group: they must stay open without a token, so an over-strict fix would also be caught.
4. **Privilege escalation through the profile API** (`role` in `PUT /api/users/me`) is included, because it is the shortest way around access control. It belongs to FR-04 but breaks FR-12 if it works.
5. Status codes are not in the spec; 401 (no or bad token) and 403 (valid token, wrong role) are assumed.

Input variables

ID	Variable	Condition / constraint	Type	From spec or Assumption
FR-12_IN_01	Account role used to log in to the admin web app	Set: {admin, user}; must be admin	Set	Spec
FR-12_IN_02	Credentials at the admin web login	Must be a correct email/password pair	Set	Assumption (FR-02 applies)
FR-12_IN_03	`Authorization` header on a protected API request	Set: {present, missing}	Set	Spec
FR-12_IN_04	Header scheme	Must be exactly `Bearer <token>`; any other form is rejected	Text	Spec (format) + Tester decision (D6)
FR-12_IN_05	Token integrity	Must be a token issued by the server and unmodified	Set	Spec
FR-12_IN_06	`role` claim in the token	Must be `admin`	Set	Spec
FR-12_IN_07	Token age	Expiry not specified; not a requirement here, only recorded	Date/time	Tester decision (D4)
FR-12_IN_08	Token owner's current account state	Set: {unchanged, deleted, role changed since login}; token must stop working once the owner is deleted or demoted	Set	Tester decision (D5)
FR-12_IN_09	Protected endpoint path	Set: `/api/admin/users`, `/api/admin/orders`, `/api/admin/import-products`, `/api/admin/coupons`, `/api/products`, `/api/categories`, `/api/coupons` (coupon writes tested on both paths)	Set	Spec + Tester decision (D1)
FR-12_IN_10	HTTP method	Set: {GET, POST, PUT, DELETE}; on products/categories only POST/PUT/DELETE are protected; on `/api/coupons` GET is protected too	Set	Spec + Tester decision (D2)
FR-12_IN_11	Public read endpoint (control group)	Set: `GET /api/products`, `GET /api/products/:id`, `GET /api/categories`	Set	Spec (API 3.1, 3.2, 3.4)
FR-12_IN_12	Admin web page opened without logging in (direct URL or refresh)	Set: {logged in as admin, not logged in}	Set	Assumption
FR-12_IN_13	Token stored in the admin web app's browser storage	Set: {admin token, user token, random text}	Set	Assumption
FR-12_IN_14	`role` field sent in `PUT /api/users/me`	Must be ignored	Set	Spec (SEC-06, FR-04)

Output variables

ID	Variable	Condition / constraint	Type	From spec or Assumption
FR-12_OUT_01	Protected API with a valid admin token	Request performed (HTTP 2xx)	Set	Spec
FR-12_OUT_02	Protected API without a valid token	Rejected, HTTP 401	Set	Spec (SEC-02) + Tester decision (D3)
FR-12_OUT_03	Protected API with a valid non-admin token	Rejected, HTTP 403 (403 or 404 for a non-existent admin path)	Set	Spec (SEC-03) + Tester decision (D3, D8)
FR-12_OUT_04	Data after a rejected request	Unchanged (nothing created, edited or deleted)	Set	Spec (implied)
FR-12_OUT_05	Response body of a rejected request	No data from the protected resource; no internal details (stack trace, secret)	Set	Assumption
FR-12_OUT_06	Public read endpoint without a token	Allowed (HTTP 200)	Set	Spec (API 3.1, 3.4)
FR-12_OUT_07	Admin web login with an admin account	Admin dashboard shown	Set	Spec
FR-12_OUT_08	Admin web login with a user account	Rejected with a message; no admin page shown	Set	Spec (FR-12) + Assumption (wording)
FR-12_OUT_09	Admin web login with wrong credentials	Error message; no admin page shown	Set	Assumption
FR-12_OUT_10	Admin web page without login	Redirected to the admin login; no data shown	Set	Assumption
FR-12_OUT_11	Admin web app with a non-admin or random token in storage	No admin data shown (API calls rejected)	Set	Assumption
FR-12_OUT_12	Account role after `PUT /api/users/me` with `role`	Unchanged	Set	Spec (SEC-06)

Decision log (spec silent or contradictory, decided by the tester)

Bugs raised from these decisions must say they rest on a tester decision, not on the spec.

#	Question	Decision
D1	FR-12 protects `/api/coupons` writes; the API spec puts them at `/api/admin/coupons`	**Test both paths.** (IN_09)
D2	Is `GET /api/coupons` admin-only?	**Yes**, as API 5.2 says "for Admin". (IN_10)
D3	Status codes	**401** for a missing or bad token, **403** for a valid token with the wrong role. (OUT_02, OUT_03)
D4	Token expiry	**Not a requirement** in this feature; only record whether tokens expire. (IN_07)
D5	Token after its owner is deleted or demoted	**Must stop working.** (IN_08)
D6	Header scheme	Only exactly **`Bearer <token>`** is accepted; `bearer`, a missing scheme or another scheme is rejected. (IN_04)
D7	Default admin password differs between README (`Admin123!`) and setup guide (`admin123`)	**Report as a documentation bug.** Use whichever works for testing.

#	Question	Decision
D8	Non-admin calling a non-existent admin path (e.g. `/api/admin/xyz`)	**403 or 404**, both acceptable. (OUT_03)